

Week 6 Day 1

OWASP (Open Web Application Security project)

Top 10: It is a regularly updated report outlining security concerns for web apps security, focusing on the 10 most critical risk.

1. Broken Access Control

A user can access information or actions they are not allowed to access. Eg:- A normal user changes /user/123 to /user/124 and sees another user's account.

2. Cryptographic Failures

Sensitive information is not properly protected with encryption. Eg:- A website stores passwords in plain text, and attackers steal them from the database.

3. Injection

An attacker sends malicious input that is interpreted as code or a database command. For eg:- An attacker enters SQL code into a login form to bypass authentication.

4. Insecure Design

The security problems are built into the application's design or business logic. Eg. A password reset system uses easy to guess ~~security~~ security question "What is your country"

5. Security Misconfiguration

Security settings are incorrectly configured or left at unsafe defaults. Eg. A website displays detailed error messages that reveal database information.

6. Vulnerable and Outdated Components

The application uses old software or libraries with known security vulnerability. For eg:- A website uses an outdated version of a framework with a known security bug.

7. Identification and Authentication Failures

Weak login or auth allows attacker to access other user's accounts. For eg. An attacker repeatedly tries stolen passwords because the website has no login rate limit.

8. Software and Data Integrity Failures.

The application does not verify that software; updates or data come from trusted source. For eg: An application installs a malicious software update from an untrusted source.

9. Security Logging and Monitoring Failures.

Attacks are not properly recorded, detected or reported. For eg: An attacker makes thousands of ~~bad~~ failed login attempts, but the system does not alert the administrators.

10. Server-Side Request Forgery (SSRF)

An attacker tricks a server into making requests to resources it should not access.

An attacker tricks a web server into accessing an internal admin page that is not publicly accessible.

3. IAST

→ Interactive Application Security Testing.

It combines both static and dynamic testing to provide real time feedback during application runtime.

4. SCA

Software Composition Analysis scans third party libraries and dependencies for vulnerabilities, outdated components, and license issues.

5. Manual Penetration Testing

It leverage human expertise to simulate sophisticated attacks. to uncover business logic flaws, chaining exploits or social engineering vector that tools miss

Objectives of Security Testing

- Find security weaknesses and vulnerabilities
- Test resistance against attacks and unauthorized access
- Ensure compliance with security standard.
- Protect sensitive data
- Reduce security risk before deployment.

Phase of Security testing

1. Planning - Defining scope, objectives and test.
2. Reconnaissance - Collect information about the system
3. Threat Modeling - Identify possible threats and attack methods
4. Vulnerability Scanning - Find potential security weaknesses
5. Exploitation - Safely test whether vulnerabilities can be exploited
6. Risk Assessment - Determine the severity and impact of vulnerabilities
7. Reporting - Document finding and recommend solutions.
8. Remediation Fix the identified security issue
9. Retesting - Test again to confirm the issues are fixed.